

Mini Project

Secure a Basic Website:

1. Find a simple HTML/PHP website (or use an open-source project)

index.html

```
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4   <meta charset="UTF-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1.0">
6   <title>Login Page</title>
7 </head>
8 <body>
9   <h2>Login</h2>
10  <form action="login.php" method="POST">
11    <label for="username">Username:</label>
12    <input type="text" name="username" required>
13    <br>
14    <label for="password">Password:</label>
15    <input type="password" name="password" required>
16    <br>
17    <button type="submit">Login</button>
18  </form>
19 </body>
20 </html>
```

db.php

```
1 <?php
2 $server = "localhost";
3 $username = "root";
4 $password = "";
5 $database = "user123";
6
7 $conn = mysqli_connect($server, $username, $password, $database);
8
9 if($conn){
10   echo "success";
11 }
12 else{
13   die("Error". mysqli_connect_error());
14 }
15 >
```

login.php

```
1 <?php
2
3 if (!isset($_SERVER['HTTPS']) || $_SERVER['HTTPS'] !== 'on') {
4   header("Location: https://" . $_SERVER['HTTP_HOST'] . $_SERVER['REQUEST_URI']);
5   exit();
6 }
7
8 session_start();
9 $host = "localhost";
10 $user = "root";
11 $pass = "";
12 $dbname = "user123";
13
14 // Database connection
15 $conn = new mysqli($host, $user, $pass, $dbname);
16
17 // Check connection
18 if ($conn->connect_error) {
19   die("Database Connection Failed: " . $conn->connect_error);
20 }
21
22 if ($_SERVER["REQUEST_METHOD"] == "POST") {
23   // Trim & Sanitize Input
24   $username = trim(htmlspecialchars($_POST['username'], ENT_QUOTES, 'UTF-8'));
25   $password = trim(htmlspecialchars($_POST['password'], ENT_QUOTES, 'UTF-8'));
26
27   // Validate Username (Only letters & numbers allowed)
28   if (!preg_match("/^[a-zA-Z0-9]{4}$/", $username)) {
29     die("Invalid username! Only letters and numbers are allowed.");
30   }
31
32   // Validate Password Length (Minimum 6 characters)
33   if (strlen($password) < 6) {
34     die("Password must be at least 6 characters long.");
35   }
36
37   // Prevent SQL Injection (Use Prepared Statements)
38   $stmt = $conn->prepare("SELECT password FROM users WHERE username = ?");
39   if (!$stmt) {
40     die("SQL Error: " . $conn->error);
41   }
42 }
```

```
22 if ($_SERVER["REQUEST_METHOD"] == "POST") {
35 }
36
37 // Prevent SQL Injection (Use Prepared Statements)
38 $stmt = $conn->prepare("SELECT password FROM users WHERE username = ?");
39 if (!$stmt) {
40   die("SQL Error: " . $conn->error);
41 }
42
43 $stmt->bind_param("s", $username);
44 $stmt->execute();
45 $result = $stmt->get_result();
46
47 // If user exists, proceed with login
48 if ($row = $result->fetch_assoc()) {
49   // Escape output when displaying user data or any other dynamic content
50   $username_display = htmlspecialchars($username, ENT_QUOTES, 'UTF-8'); // Escaped output
51   echo "Welcome, " . $username_display; // Placeholder for login success message
52 } else {
53   echo "No user found with that username.";
54 }
55
56 $stmt->close();
57
58 $conn->close();
59 >
```

Implement basic security measures like input validation, HTTPS enforcement, and XSS prevention.

1. input validation

```
// ✅ Validate Username (Only letters & numbers allowed)
if (!preg_match("/^[a-zA-Z0-9]+$/", $username)) {
    die("❌ Invalid username! Only letters and numbers are allowed.");
}

// ✅ Validate Password Length (Minimum 6 characters)
if (strlen($password) < 6) {
    die("❌ Password must be at least 6 characters long.");
}
```

2. HTTPS enforcement

```
if (!isset($_SERVER['HTTPS']) || $_SERVER['HTTPS'] !== 'on') {
    header("Location: https://" . $_SERVER['HTTP_HOST'] . $_SERVER['REQUEST_URI']);
    exit();
}
```

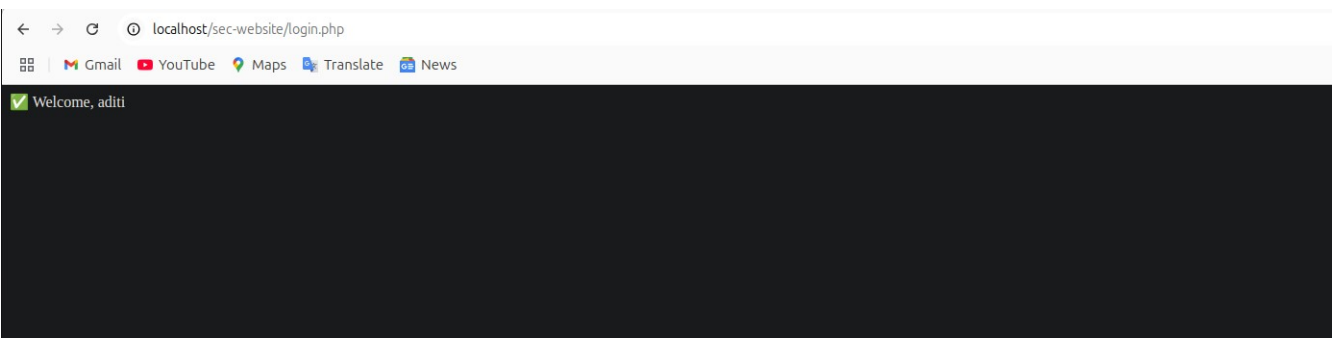
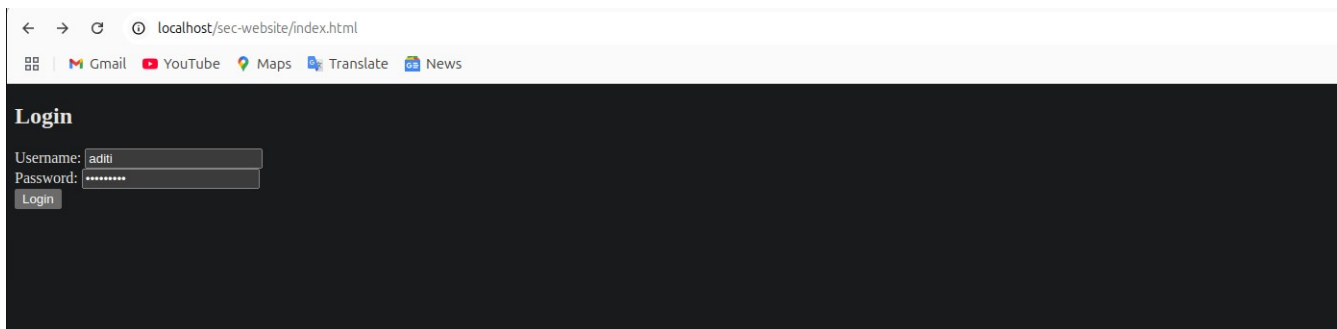
3) XSS prevention

```
// Trim & Sanitize Input
$username = trim(htmlspecialchars($_POST['username'], ENT_QUOTES, 'UTF-8'));
$password = trim(htmlspecialchars($_POST['password'], ENT_QUOTES, 'UTF-8'));
```

secure display

```
// Escape output when displaying user data or any other dynamic content
$username_display = htmlspecialchars($username, ENT_QUOTES, 'UTF-8'); // Escaped output
echo "✅ Welcome, " . $username_display; // Placeholder for login success message
```

OUTPUT :



Problem I am facing

while HTTPS enforcement :

